



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



TVM-2026-0001 GreatXML and the BitLocker Recovery Boundary

CVE / Vulnerability Threat Intelligence Report

Classification	TLP:CLEAR
Published	2026-07-06
Version	1.0
Author	Lost Boys Cyber
Report Type	CVE / Vulnerability Threat Intelligence Report

TLP:CLEAR | Lost Boys Cyber | TVM-2026-0001 GreatXML and the BitLocker Recovery Boundary - CVE / Vulnerability Threat Intelligence Report

Published: 2026-07-06 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
 - 4.1. Vulnerability and Exposure Metadata
 - 4.2. What TVM-2026-0001 Means Operationally
 - 4.3. GreatXML Technical Mechanics Supported by Public Material
 - 4.4. Historical Context: BitLocker Boundary Issues Recur
 - 4.5. MITRE ATT&CK Context
5. Threat Context
6. Detection and Hunting
 - 6.1. Detection Coverage Summary
 - 6.2. Safe Endpoint Validation Commands
 - 6.3. Defender XDR Advanced Hunting
 - 6.4. Example Sigma Logic
 - 6.5. Hunt Hypotheses
7. Recommendations
8. References

1. Executive Summary

TVM-2026-0001 is a Microsoft Defender Vulnerability Management signal associated in public reporting with GreatXML, a claimed Windows recovery-boundary bypass involving BitLocker, Windows Recovery Environment (WinRE), Microsoft Defender Offline Scan state, and unattended setup behavior. The identifier should not be treated as a normal CVE. Microsoft documentation states that Defender Vulnerability Management may show zero-day weaknesses without assigned CVE IDs under internal temporary names resembling `TVM-XXXX-XXXX`; that is the most responsible framing for TVM-2026-0001 until Microsoft publishes a public advisory, assigns a CVE, or updates the portal record.

The current evidence supports a high-priority exposure-management response, not a claim that BitLocker cryptography has been broken. Public GreatXML material and third-party reporting describe a workflow in which an attacker places `unattend.xml` and a `Recovery` directory on the recovery partition after or during Defender Offline Scan conditions, then reboots into WinRE to obtain a command shell with access to the BitLocker-protected operating-system volume. The risk is therefore best understood as abuse of a recovery/offline security workflow that can cross the boundary users expect BitLocker to enforce on lost, stolen, serviced, or physically accessed endpoints.

Lost Boys Cyber assesses the issue as a material physical-access and local-administration risk for Windows laptops, administrator workstations, executive devices, field devices, and systems whose BitLocker protection relies on TPM-only unlock without pre-boot authentication. Confidence is high that TVM-2026-0001 is a real Defender Vulnerability Management temporary identifier pattern and high that GreatXML is publicly available as a proof-of-concept claim. Confidence is medium that every TVM-flagged endpoint is practically exploitable, because official Microsoft public technical confirmation and affected-build specificity remain limited.

Executive Assessment	Judgment
Tracking identifier	`TVM-2026-0001`
Identifier type	Microsoft Defender Vulnerability Management temporary/non-CVE weakness signal
Publicly associated name	GreatXML
Primary security boundary	BitLocker / WinRE / Defender Offline Scan recovery workflow
Public exploit status	Public GitHub PoC repository and `unattend.xml` payload are available
Practical risk	Physical-access or local-admin recovery-boundary bypass, especially on portable high-value Windows endpoints
What is not proven	Universal exploitation, remote exploitation, or a break of BitLocker encryption primitives
Immediate priority	Validate affected devices in Defender XDR, inventory BitLocker/WinRE/Defender Offline Scan state, harden TPM-only and recovery workflows, and hunt for recovery-partition tampering

2. Intelligence Requirement

This report answers the following requirement: what does TVM-2026-0001 likely mean, how should defenders interpret its relationship to GreatXML and BitLocker, and what detection, hunting, and hardening actions are appropriate before Microsoft publishes complete public CVE-level metadata?

Question	Assessment
Is TVM-2026-0001 a CVE?	No public CVE record under that identifier was found during collection. Microsoft documents `TVM-XXXX-XXXX` as an

	internal temporary naming pattern for zero-days without assigned CVE IDs in Defender Vulnerability Management.
Why is GreatXML relevant?	Public reporting links GreatXML to a BitLocker bypass claim involving WinRE, Defender Offline Scan state, and `unattend.xml` behavior.
Is BitLocker cryptography broken?	No public evidence shows a cryptographic break. The issue is more accurately a recovery-environment trust-boundary problem.
Who should care first?	Organizations with portable Windows endpoints, privileged users, high-value laptops, TPM-only BitLocker, weak physical-custody controls, enabled WinRE, or unmanaged recovery partition workflows.
Should teams run the public PoC?	No. Production validation should be non-destructive and evidence-driven; do not trigger Defender Offline Scan or modify recovery partitions just to test exposure.
What remains uncertain?	Official affected versions, final Microsoft remediation status, exact TVM portal fields by tenant, and whether the no-prior-offline-scan path is broadly reproducible.

3. Source Review and Confidence

Source	Contribution	Confidence
Microsoft Learn: Mitigate zero-day vulnerabilities	Documents the Defender Vulnerability Management behavior where a zero-day without CVE may appear as an internal temporary `TVM-XXXX-XXXX` name.	High
Microsoft Learn: Defender Vulnerability Management overview	Defines TVM as Microsoft's exposure-management product using device assessment, threat intelligence, business context, and remediation workflows.	High
Microsoft Learn: `DeviceTvmSoftwareVulnerabilities` advanced hunting table	Provides the hunting table context and the important limitation that TVM tables are not ingested into Microsoft Sentinel by default.	High
Microsoft Learn: Microsoft Defender Offline Scan	Documents the offline scan workflow and the `C:\ProgramData\Microsoft\Windows Defender\Offline Scanner` path.	High
Microsoft Learn: REAgentC command-line options	Documents `reagentc.exe` as the Windows Recovery Environment configuration and recovery-options administration tool.	High
MSNightmare/GreatXML GitHub repository and raw `unattend.xml`	Primary public PoC material: reproduction claim, `unattend.xml`, `Recovery` directory workflow, and SYSTEM shell target in WinRE.	Medium to High for public PoC content; Medium for universal exploitability
SecurityWeek and The Hacker News reporting	Corroborate public GreatXML/BitLocker bypass reporting and Defender Offline	Medium

	Scan framing.	
Hive Security and Cyderes analysis	Provide a more cautious recovery-boundary interpretation that avoids overstating BitLocker cryptographic compromise.	Medium
NVD records for `CVE-2022-41099` and `CVE-2026-45585`	Historical context showing BitLocker/WinRE recovery-boundary vulnerabilities and the importance of TPM+PIN and WinRE-specific remediation.	High for context
CISA Known Exploited Vulnerabilities catalog snapshot `2026.07.01`	Negative-evidence check: `TVM-2026-0001`, `GreatXML`, and `CVE-2026-45585` were not present in the reviewed KEV JSON snapshot.	High for catalog absence at review time

Overall confidence is high that TVM-2026-0001 should be treated as a Defender Vulnerability Management weakness record rather than a public CVE. Confidence is medium-to-high that the publicly discussed risk is GreatXML-style recovery-boundary abuse. Confidence is medium on broad exploitability because public PoC claims outpace complete vendor-published technical detail.

4. Key Findings

4.1. Vulnerability and Exposure Metadata

Field	Value
Identifier	`TVM-2026-0001`
Identifier namespace	Microsoft Defender Vulnerability Management temporary/internal weakness naming pattern
Public name used in reporting	GreatXML
Affected boundary	Windows Recovery Environment, Microsoft Defender Offline Scan state, unattended setup behavior, and BitLocker-protected OS volume expectations
Public CVE status	No public CVE located under `TVM-2026-0001` as of 2026-07-06 collection
Public PoC status	Public GitHub repository `MSNightmare/GreatXML`, created 2026-06-11, with approximately 588 stars and 239 forks in the GitHub API snapshot reviewed on 2026-07-06
Attacker position	Physical access, recovery-partition access, or local administrative/control path sufficient to place recovery files and reboot into WinRE/offline scan state
Likely impact	Command shell / system-level access to a BitLocker-protected volume from the recovery environment under reported conditions
Most exposed assets	Portable Windows endpoints, privileged workstations, field devices, executive laptops, repair-chain exposed assets, TPM-only BitLocker configurations
Highest-value mitigations	TPM+PIN or startup key for high-risk devices, recovery-key escrow, WinRE hygiene, Defender version verification, recovery

partition integrity monitoring, and physical-custody controls

4.2. What TVM-2026-0001 Means Operationally

A TVM record is not the same thing as a CVE. A CVE is a public vulnerability identifier used across vendor advisories, NVD, scanner plugins, SBOM processes, and patch dashboards. A TVM identifier is a Defender Vulnerability Management weakness record surfaced inside Microsoft's exposure-management product. Microsoft's zero-day guidance explicitly says that when a vulnerability does not have a CVE-ID, the Defender portal can show a zero-day label under a temporary name that looks like `TVM-XXXX-XXXX`.

The operational implication is that defenders should preserve the TVM portal record, export affected-device details, and validate local exposure conditions instead of waiting for public CVE metadata. The absence of a CVE reduces outside corroboration; it does not make the endpoint signal meaningless.

TVM Signal	Analyst Interpretation	Defensive Action
TVM-2026-0001 appears on one or more devices	Defender Vulnerability Management has identified a non-CVE weakness record	Export affected devices, current recommendation text, severity, remediation guidance, and evidence timestamps
Record is associated with GreatXML or BitLocker	The risk likely involves the WinRE / Defender Offline Scan / BitLocker boundary	Prioritize BitLocker, WinRE, Defender Offline Scan, and recovery-partition checks
Device uses TPM-only BitLocker	Physical-access attacks become more relevant because unlock is transparent during normal boot flows	Evaluate TPM+PIN/startup key for high-risk device groups
WinRE is enabled	Recovery workflow is available and should be treated as part of the security boundary	Confirm recovery image version, location, and policy need; do not disable blindly without recovery planning
Defender Offline Scan artifacts exist	GreatXML public claims become more relevant because offline scan state is central to the PoC narrative	Investigate timing, initiating account, and post-scan recovery activity
No public CVE exists	Public metadata is incomplete	Track Microsoft advisory changes and keep the report marked as confidence-bounded

4.3. GreatXML Technical Mechanics Supported by Public Material

The public GreatXML README states two reproduction paths. First, if Defender Offline Scan had been initiated on the victim machine previously, the attacker copies `unattend.xml` and a `Recovery` directory to the root of the recovery partition, then reboots to WinRE using Shift+Restart; if successful, a shell with unrestricted access to the BitLocker volume spawns. Second, if Defender Offline Scan was never initiated, the README asserts the attacker must log in and initiate it or find another way to boot into WinRE in offline scan state.

The raw `unattend.xml` payload is consistent with this recovery-automation framing. It contains a `windowsPE` `RunSynchronous` command that writes and executes `X:\pe.cmd`, with the command `start X:\Windows\System32\conhost.exe`. The file also contains normal unattended-setup sections and generated-script scaffolding, which reinforces the interpretation that the exploit path abuses legitimate Windows setup/recovery mechanisms rather than BitLocker encryption internals.

Public Artifact	Defensive Relevance
`unattend.xml` at recovery partition root	High-value file-integrity and recovery-partition monitoring target
`Recovery` directory copied to recovery partition root	Strong public-PoC staging signal if observed outside authorized

	servicing
`X:\Windows\System32\conhost.exe` in unattend workflow	Indicator of command-shell spawning inside WinRE / Windows PE context
Defender Offline Scan state	Central precondition in the public README and third-party analysis
Shift+Restart / WinRE boot	Relevant user-action or physical-access transition to investigate
Empty-password local `Admin` / `User` account scaffolding in payload	Suspicious if found in enterprise unattended setup material outside a controlled lab

4.4. Historical Context: BitLocker Boundary Issues Recur

TVM-2026-0001 should be interpreted in the same class of risk as prior WinRE and BitLocker boundary issues. `CVE-2022-41099` was a BitLocker security feature bypass that required WinRE-specific remediation through KB5025175-style update workflows. `CVE-2026-45585`, publicly referred to as YellowKey, was assigned to provide mitigation guidance for a publicly disclosed Windows BitLocker bypass; NVD records Microsoft's statement that TPM+PIN makes that vulnerability not exploitable.

The shared lesson is that BitLocker's practical security boundary includes more than the encryption algorithm. Firmware state, TPM policy, Secure Boot, WinRE, recovery partitions, Defender Offline Scan, deployment automation, local administrator rights, recovery-key escrow, and physical custody all affect whether disk encryption protects the asset in the situations that matter.

4.5. MITRE ATT&CK Context

Tactic	Technique	Relevance
Initial Access	`T1200` Hardware Additions	Physical access, removable media, or recovery partition manipulation can be part of the attack path.
Defense Evasion	`T1553.005` Subvert Trust Controls: Mark-of-the-Web Bypass / trust-control abuse	Contextual mapping for abuse of trusted recovery/offline workflows; not a perfect fit, but useful for trust-boundary analysis.
Privilege Escalation	`T1068` Exploitation for Privilege Escalation	If the workflow produces SYSTEM-level or unrestricted shell access, the outcome is privilege escalation.
Defense Evasion	`T1562.001` Impair Defenses: Disable or Modify Tools	Post-access actors may tamper with Defender, BitLocker, EDR, or recovery configuration.
Persistence	`T1547` Boot or Logon Autostart Execution	Follow-on persistence may be established once the protected volume is writable.
Impact	`T1485` Data Destruction / `T1005` Data from Local System	Once the OS volume is accessible, actors can read, alter, or destroy local data.

5. Threat Context

GreatXML is most relevant to organizations that rely on BitLocker to protect endpoints outside direct physical control. Laptops are stolen, left in hotel rooms, shipped for repair, accessed by contractors, and handled by help desks. A recovery-boundary bypass changes the risk calculation for those situations because it may allow a physically present attacker to reach a protected volume without attacking the encryption algorithm.

The issue also intersects with endpoint-management practice. Defender Offline Scan is a legitimate security workflow, WinRE is a legitimate recovery component, and unattended setup files are legitimate deployment artifacts. That means a clean defensive response cannot simply declare the components malicious. Teams must identify whether the combination is expected in their environment, whether high-risk devices use TPM-only unlock, whether recovery keys are escrowed, and whether recovery partitions are monitored for unauthorized changes.

Threat Scenario	Assessment
Stolen or lost laptop with TPM-only BitLocker	Highest concern. Physical access and transparent boot protection make recovery-boundary weaknesses more consequential.
Repair-chain or evil-maid access to executive/developer/admin workstation	High concern. Brief custody may be enough to stage recovery files if recovery partition access is possible.
Local administrator abuses recovery workflow	Plausible. A user or malware with sufficient local rights may initiate Defender Offline Scan state or alter recovery configuration.
Remote exploitation without local/physical foothold	Not currently supported by reviewed evidence. Treat as unproven.
Commodity attacker integration	Plausible if the workflow proves reliable, but requires physical/local conditions that limit mass remote use.
Red-team validation	Likely, because public PoC material is concise and the issue is attractive for endpoint-hardening exercises.

The most important analyst bottom line is restraint: report this as a Defender Vulnerability Management exposure tied to a GreatXML recovery-boundary claim, not as a universal BitLocker break. That framing lets security teams act quickly without overstating the evidence.

6. Detection and Hunting

6.1. Detection Coverage Summary

Signal	Telemetry Source	Analytic Goal	Coverage Confidence
TVM-2026-0001 in Defender Vulnerability Management	Defender XDR Advanced Hunting `DeviceTvmSoftwareVulnerabilities`	Build affected-device inventory and remediation queue	Medium; tenant schema may vary for non-CVE records
`unattend.xml` or `Recovery` directory writes in recovery locations	MDE `DeviceFileEvents`, Sysmon file events, EDR file telemetry	Identify GreatXML-style staging or unauthorized recovery partition modification	Medium to High if recovery partition activity is collected
`reagentc.exe`, `manage-bde.exe`, `Start-MpWDOScan`, or Defender Offline Scan commands	MDE `DeviceProcessEvents`, PowerShell logs, Windows Defender Operational log	Identify recovery/offline scan preparation or suspicious administrative activity	Medium
Defender Offline Scanner path changes	File telemetry on `C:\ProgramData\Microsoft\Windows Defender\Offline Scanner`	Discover offline scan state and artifacts without initiating a scan	Medium
WinRE boot, recovery reset, or BitLocker recovery events	Windows Event Logs, endpoint management logs, help desk records	Correlate physical/recovery activity with later suspicious access	Low to Medium; event detail varies

Unexpected post-recovery security tampering	MDE/Sysmon process, registry, service, and BitLocker events	Detect follow-on actions after a successful bypass	Medium
---	---	--	--------

6.2. Safe Endpoint Validation Commands

The following commands are for defensive inventory and validation. Do not run public PoC code, do not initiate Defender Offline Scan as a test, and do not modify recovery partitions without change approval and verified recovery-key escrow.

<pre># Defender engine, platform, and protection state Get-MpComputerStatus Select-Object ` AMProductVersion, AMEngineVersion, AMServiceVersion, AntivirusSignatureVersion, AntivirusSignatureLastUpdated, RealTimeProtectionEnabled, IoavProtectionEnabled, NISEnabled, IsTamperProtected</pre>
<pre># BitLocker protection and key protector inventory Get-BitLockerVolume Select-Object ` MountPoint, VolumeStatus, ProtectionStatus, EncryptionMethod, KeyProtector manage-bde -status manage-bde -protectors -get C:</pre>
<pre># Windows Recovery Environment state reagentc /info</pre>
<pre># Check for Defender Offline Scan artifacts without starting a scan \$offlineScannerPath = "C:\ProgramData\Microsoft\Windows Defender\Offline Scanner" if (Test-Path \$offlineScannerPath) { Get-ChildItem -Path \$offlineScannerPath -Force -Recurse -ErrorAction SilentlyContinue Select-Object FullName, Length, LastWriteTime } else { Write-Output "No Defender Offline Scanner directory found at the documented path." }</pre>
<pre># Local event discovery for Defender, recovery, and BitLocker activity Get-WinEvent -LogName "Microsoft-Windows-Windows Defender/Operational" -MaxEvents 200 Select-Object TimeCreated, Id, ProviderName, Message Get-WinEvent -LogName "System" -MaxEvents 500 Where-Object { \$_.Message -match "recovery WinRE BitLocker Defender restart" } Select-Object TimeCreated, Id, ProviderName, Message</pre>

6.3. Defender XDR Advanced Hunting

<pre>// Discover whether the tenant exposes TVM-2026-0001 in Defender Vulnerability Management. // Run in Defender XDR Advanced Hunting, not Microsoft Sentinel unless TVM data is custom-ingested. DeviceTvmSoftwareVulnerabilities where tostring(CveId) =~ "TVM-2026-0001" or tostring(VulnerabilityId) =~ "TVM-2026-0001" or tostring(VulnerabilityDescription) has "TVM-2026-0001" project DeviceName, DeviceId, OSPlatform, OSVersion, CveId, VulnerabilitySeverityLevel, SoftwareName, SoftwareVersion, RecommendedSecurityUpdate order by DeviceName asc</pre>
<pre>// Join TVM exposure to device inventory and business grouping. let tvmWeakness = DeviceTvmSoftwareVulnerabilities</pre>

```

| where tostring(CveId) =~ "TVM-2026-0001"
|   or tostring(VulnerabilityId) =~ "TVM-2026-0001"
|   or tostring(VulnerabilityDescription) has "TVM-2026-0001"
| project DeviceId, DeviceName, OSPlatform, OSVersion,
|       VulnerabilitySeverityLevel, SoftwareName, SoftwareVersion;
tvmWeakness
| join kind=leftouter (
|   DeviceInfo
|   | summarize arg_max(Timestamp, *) by DeviceId
|   | project DeviceId, ExposureLevel, OnboardingStatus, MachineGroup, LoggedOnUsers
) on DeviceId
| order by VulnerabilitySeverityLevel desc, DeviceName asc

// Recovery partition and unattended setup artifact hunt.
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has_any (@"\Recovery\WindowsRE", @"\Recovery\", @"\Windows\System32\Recovery")
|   or FileName in~ ("unattend.xml", "winpeshl.ini")
| project Timestamp, DeviceName, ActionType, FileName, FolderPath, SHA256,
|       InitiatingProcessAccountName, InitiatingProcessFileName,
|       InitiatingProcessCommandLine
| order by Timestamp desc

// Recovery, BitLocker, and Defender Offline Scan command activity.
DeviceProcessEvents
| where Timestamp > ago(30d)
| where FileName in~ ("reagentc.exe", "manage-bde.exe", "MpCmdRun.exe", "powershell.exe", "cmd.exe")
| where ProcessCommandLine has_any ("reagentc", "manage-bde", "Start-MpWDOScan", "Offline",
"BitLocker", "Recovery", "unattend.xml")
| project Timestamp, DeviceName, AccountName, FileName, ProcessCommandLine,
|       InitiatingProcessFileName, InitiatingProcessCommandLine
| order by Timestamp desc

// Defender Offline Scanner artifact discovery from normal OS telemetry.
DeviceFileEvents
| where Timestamp > ago(30d)
| where FolderPath has @"\ProgramData\Microsoft\Windows Defender\Offline Scanner"
| project Timestamp, DeviceName, ActionType, FileName, FolderPath, SHA256,
|       InitiatingProcessAccountName, InitiatingProcessFileName,
|       InitiatingProcessCommandLine
| order by Timestamp desc

```

6.4. Example Sigma Logic

```

title: Possible GreatXML Recovery Boundary Staging
id: 56d1d5e2-a2e1-49b5-bb11-202600010001
status: experimental
description: Detects suspicious process activity consistent with GreatXML-style recovery partition or
Defender Offline Scan staging.
references:
- https://github.com/MSNightmare/GreatXML
- https://learn.microsoft.com/en-us/defender-vulnerability-management/tvm-zero-day-vulnerabilities
author: Lost Boys Cyber
date: 2026-07-06
logsource:
  product: windows
  category: process_creation
detection:
  selection_tools:
    Image|endswith:
      - '\reagentc.exe'
      - '\manage-bde.exe'
      - '\MpCmdRun.exe'
      - '\powershell.exe'
      - '\cmd.exe'
  selection_terms:
    CommandLine|contains:
      - 'Start-MpWDOScan'
      - 'unattend.xml'

```

```

- '\Recovery\'
- 'Windows Defender\Offline Scanner'
- 'winpeshl.ini'
condition: selection_tools and selection_terms
falsepositives:
- authorized Windows deployment, imaging, recovery testing, Autopilot provisioning, or BitLocker
administration
- help desk recovery operations during approved change windows
level: medium
tags:
- attack.privilege_escalation
- attack.t1068
- attack.t1200

```

6.5. Hunt Hypotheses

- If GreatXML-style staging occurred, one or more endpoints should show unusual recovery partition writes, `unattend.xml` placement, Defender Offline Scan artifacts, WinRE boot activity, or suspicious use of `reagentc.exe` / `manage-bde.exe` near the same time window.
- If the activity was authorized servicing, evidence should align with a change ticket, help desk session, imaging workflow, Autopilot process, or endpoint engineering account.
- If the activity was malicious or unauthorized, follow-on behavior may include local account changes, security control tampering, BitLocker protector changes, LSASS access attempts, persistence installation, or data access from normally protected user profiles.
- If the only evidence is a TVM record, the next step is exposure validation, not incident declaration. Build the affected-device queue and hardening plan first.

7. Recommendations

Priority	Owner	Recommendation	Defensive Outcome
Critical	Vulnerability Management / Endpoint Security	Export every TVM-2026-0001 record from Defender Vulnerability Management, including affected devices, severity, recommendation text, software fields, and evidence timestamps.	Preserves the volatile portal context before Microsoft renames or maps the record to a CVE.
Critical	Endpoint Engineering	Inventory BitLocker protectors for affected and high-value devices; prioritize TPM+PIN or startup key for traveling, privileged, executive, and developer endpoints where operationally feasible.	Reduces physical-access exploitability for recovery-boundary issues.
High	Windows Platform	Verify WinRE state with `reagentc /info`, confirm recovery image provenance, and ensure recovery keys are escrowed before changing recovery policy.	Prevents blind WinRE changes that break recovery while improving boundary assurance.
High	SOC / Detection Engineering	Deploy hunts for TVM exposure, recovery partition writes, `unattend.xml`, Defender Offline Scanner artifacts, `reagentc.exe`, `manage-bde.exe`, and `Start-	Provides early detection of public-PoC testing and unauthorized recovery workflow changes.

		MpWDOScan`.	
High	IT Operations / Help Desk	Require change records for Defender Offline Scan, WinRE repair, BitLocker protector changes, and recovery partition modifications.	Makes legitimate recovery work distinguishable from attacker staging.
High	Endpoint Security	Keep Microsoft Defender platform, engine, and signatures current; verify versions on endpoints rather than relying only on OS patch compliance.	Addresses adjacent Defender vulnerabilities and reduces stale-security-component risk.
Medium	Physical Security / Asset Management	Increase controls around repair-chain custody, travel devices, loaners, and lost-device response.	Aligns operational controls with the physical-access nature of the risk.
Medium	Incident Response	Retrospectively review recovery/Defender/BitLocker telemetry since 2026-06-11, the public GreatXML repository creation date.	Supports compromise assessment during the public disclosure window.
Medium	Governance	Communicate the issue as a recovery-boundary risk, not a BitLocker cryptographic failure.	Prevents panic and focuses remediation on the right control plane.

Additional analyst guidance:

- Do not run GreatXML on production systems. Use lab validation only, under written authorization, with disposable test hosts and recovery-key controls.
- Do not trigger `Start-MpWDOScan` merely to test exposure; the public claim specifically gives importance to Defender Offline Scan state.
- Treat Microsoft Sentinel TVM queries carefully. Microsoft documents that the `DeviceTvmSoftwareVulnerabilities` table is not ingested into Sentinel by default even though schema visibility may exist there.
- If Microsoft later maps TVM-2026-0001 to a CVE, update vulnerability management records and detections, but preserve the original TVM identifier as an alias for retrospective hunting.
- If disabling WinRE is considered, perform a business-impact review first. WinRE is used for legitimate recovery and reset workflows; disabling it without recovery planning can create operational risk.

8. References

- [1] Microsoft Learn, Mitigate zero-day vulnerabilities: <https://learn.microsoft.com/en-us/defender-vulnerability-management/tvm-zero-day-vulnerabilities>
- [2] Microsoft Learn, Microsoft Defender Vulnerability Management: <https://learn.microsoft.com/en-us/defender-vulnerability-management/defender-vulnerability-management>
- [3] Microsoft Learn, DeviceTvmSoftwareVulnerabilities table: <https://learn.microsoft.com/en-us/defender-xdr/advanced-hunting-devicetvmsoftwarevulnerabilities-table>
- [4] Microsoft Learn, Microsoft Defender Offline scan in Windows: <https://learn.microsoft.com/en-us/defender-endpoint/microsoft-defender-offline>
- [5] Microsoft Learn, Start-MpWDOScan: <https://learn.microsoft.com/en-us/powershell/module/defender/start-mpwdoscan>
- [6] Microsoft Learn, REAgentC command-line options: <https://learn.microsoft.com/en-us/windows-hardware/manufacture/desktop/reagentc-command-line-options>

- [7] Microsoft Learn, manage-bde status: <https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/manage-bde-status>
- [8] Microsoft Learn, manage-bde protectors: <https://learn.microsoft.com/en-us/windows-server/administration/windows-commands/manage-bde-protectors>
- [9] Penlilent, TVM-2026-0001, GreatXML, and the BitLocker Recovery Boundary: <https://www.penlilent.ai/hackinglabs/tvm-2026-0001/>
- [10] MSNightmare/GreatXML GitHub repository: <https://github.com/MSNightmare/GreatXML>
- [11] MSNightmare/GreatXML raw README: <https://raw.githubusercontent.com/MSNightmare/GreatXML/main/README.md>
- [12] MSNightmare/GreatXML raw unattend.xml: <https://raw.githubusercontent.com/MSNightmare/GreatXML/main/unattend.xml>
- [13] SecurityWeek, GreatXML zero-day exploit bypasses BitLocker: <https://www.securityweek.com/greatxml-zero-day-exploit-bypasses-bitlocker/>
- [14] The Hacker News, GreatXML exploit bypasses Windows BitLocker via recovery partition XML files: <https://thehackernews.com/2026/06/new-greatxml-exploit-bypasses-windows.html>
- [15] Hive Security, GreatXML: When a Setup File Unlocks BitLocker: <https://hivesecurity.gitlab.io/blog/greatxml-bitlocker-bypass-winre-defender-offline/>
- [16] Cyderes, GreatXML: Windows Zero-Day Turns Defender Offline Scan Into BitLocker Backdoor: <https://www.cyderes.com/howler-cell/greatxml-windows-zero-day>
- [17] NVD, CVE-2026-45585: <https://nvd.nist.gov/vuln/detail/CVE-2026-45585>
- [18] NVD, CVE-2022-41099: <https://nvd.nist.gov/vuln/detail/CVE-2022-41099>
- [19] Microsoft Support, KB5025175 update WinRE to address CVE-2022-41099: <https://support.microsoft.com/help/5025175>
- [20] CISA Known Exploited Vulnerabilities catalog JSON: https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json